

## Research Background

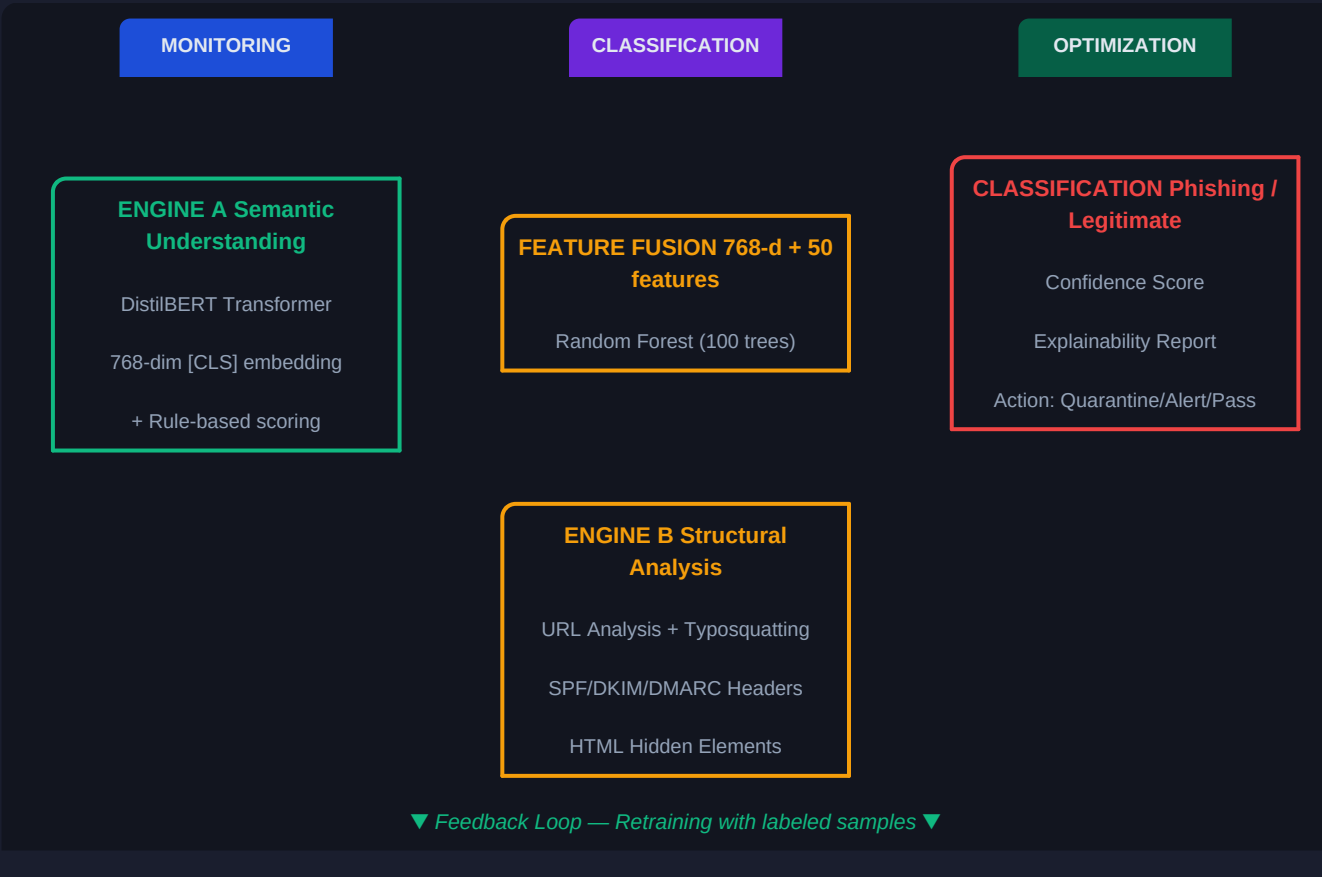
This system is based on the research paper "**Agentic AI for Phishing Detection and Prevention**" by Loo, Galindo, Romero et al. from the [Universidad Tecnológica de Honduras \(UTH\), 2025](#).

The paper proposes a novel approach to phishing detection that moves beyond traditional rule-based systems (like EBIDS) by introducing an **agentic AI architecture** capable of autonomous monitoring, intelligent classification, and continuous self-optimization. The system was validated on a dataset of **82,500 emails** from the Enron, Ling, and SpamAssassin corpuses.

|          |                     |                     |               |
|----------|---------------------|---------------------|---------------|
| 92.5%    | 6.25%               | 1.25%               | 82.5K         |
| Accuracy | False Negative Rate | False Positive Rate | Emails Tested |

## MCO Architecture

The system follows a three-phase agentic loop: Monitoring, Classification, and Optimization.



## Engine A: Semantic Understanding

Uses a DistilBERT transformer model to extract deep linguistic features from email text. The model produces a 768-dimensional embedding from the [CLS] token that captures semantic meaning.

- Urgency language detection (e.g., "account suspended", "act immediately")
- Authority impersonation scoring (CEO, PayPal, Microsoft, etc.)
- Pressure tactics identification (deadlines, threats)
- Credential harvesting phrase detection
- Generic greeting patterns (Dear Customer, Dear User)
- Grammatical anomaly analysis

## Engine B: Structural Analysis

Analyzes the technical structure of emails including URLs, headers, and HTML content to identify structural indicators of phishing attacks.

- URL analysis: IP-based, shorteners, suspicious TLDs
- Typosquatting detection (Levenshtein distance vs 45+ brands)
- SPF / DKIM / DMARC authentication validation
- Sender spoofing (display name vs domain mismatch)
- Hidden HTML elements and tracking pixels
- Embedded forms with external action URLs

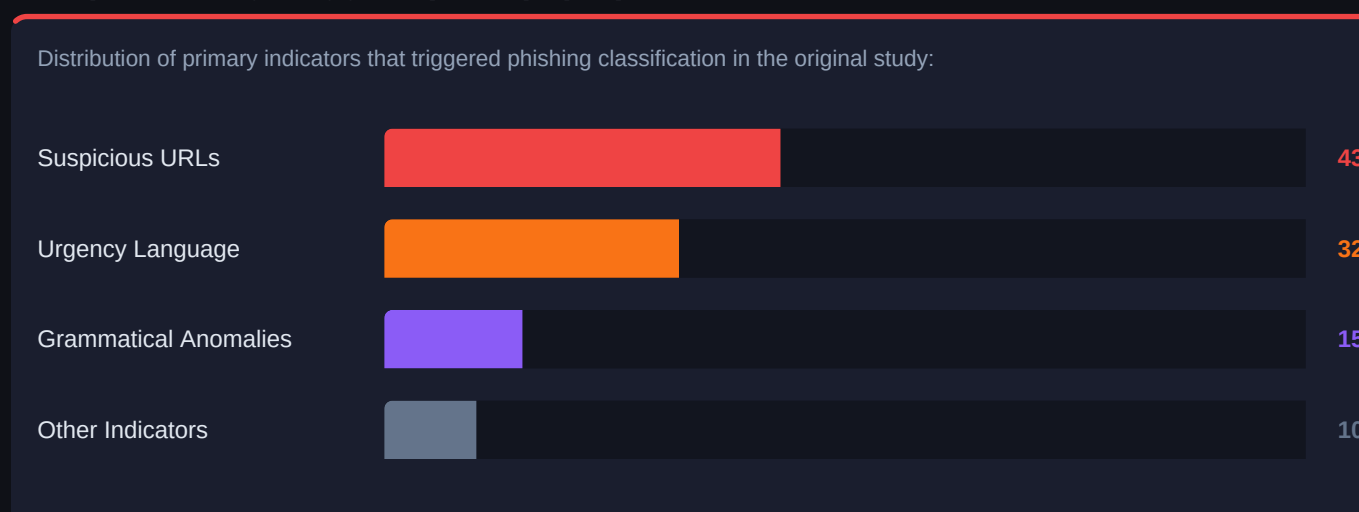
## ■ Classification Pipeline



## ■ Technology Stack

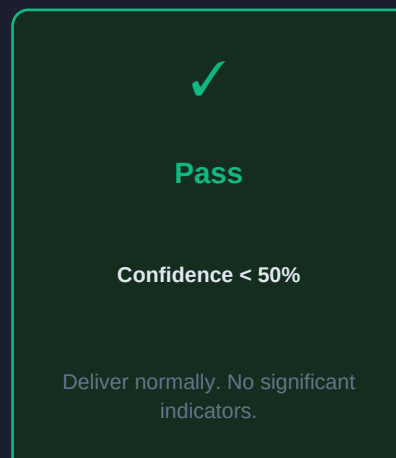
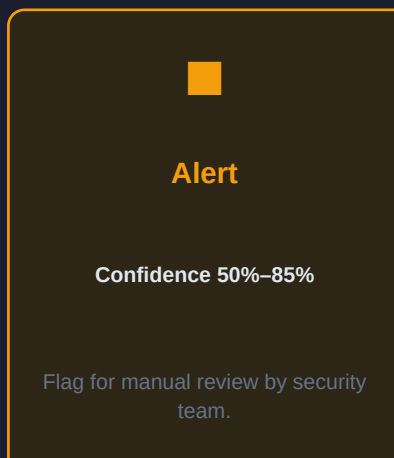
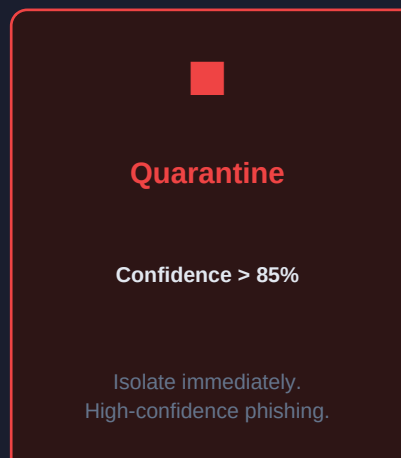
|                                                  |                                                     |                                                       |
|--------------------------------------------------|-----------------------------------------------------|-------------------------------------------------------|
| <b>Backend</b><br><br>Python 3.10+ / FastAPI     | <b>NLP Model</b><br><br>DistilBERT (HuggingFace)    | <b>Classifier</b><br><br>Random Forest (scikit-learn) |
| <b>Deep Learning</b><br><br>PyTorch              | <b>OCR</b><br><br>Tesseract + Pillow                | <b>Database</b><br><br>SQLite (persistent logs)       |
| <b>Frontend</b><br><br>Tailwind CSS / Vanilla JS | <b>URL Analysis</b><br><br>tldextract / Levenshtein | <b>AI Chat</b><br><br>Claude API (Anthropic)          |

## ■ Top Phishing Triggers (from paper)



## ■ Agentic Action Mapping

The system autonomously maps classification results to recommended actions:



## ■ Data Flow & Storage Architecture

How data flows through the system from input to persistent storage and retraining.



■ *Retraining Pipeline* — verified labeled samples feed back into the classifier

SQLite DB stores scan history, training samples, and audit log (V-06)

## ■ Adversarial Attack Taxonomy

Categories of adversarial attacks the system is designed to detect and resist:

### Semantic Evasion

- Paraphrasing urgent language to bypass NLP
- Using synonyms for credential requests
- Embedding text in images (OCR evasion)
- Unicode homograph substitution

### Structural Obfuscation

- URL shorteners and redirects
- IP-based links and hex encoding
- Typosquatting (paypa1.com, micros0ft.com)
- Header spoofing and forged SPF/DKIM

### Content Manipulation

- HTML-based hidden content injection
- Base64-encoded payloads
- CSS-hidden tracking pixels
- Obfuscated JavaScript execution

### Social Engineering

- CEO / executive impersonation (BEC)
- Brand spoofing with lookalike domains
- Reply-to address mismatch
- Pretexting with legitimate-looking invoices

## ■ Phase 2: Adversarial Evaluation

The follow-up research paper will extend this system with adversarial testing to evaluate robustness against evasion attacks. This includes:

- **Semantic Paraphrasing** — T5/GPT-based rephrasing of phishing content while preserving malicious intent
- **Structural Obfuscation** — URL encoding, homograph attacks, header spoofing techniques
- **Adversarial Retraining** — Measuring and improving robustness through adversarial sample augmentation
- **Metrics** — Accuracy, Precision, Recall, F1, FNR, FPR, Evasion Success Rate, ROC/AUC curves